מספר התלמיד הנבחן
רשום את כל תשע הספרות

הדבק כאן את מדבקת הנבחן

האוניברסיטה הפתוחה

י"ט באייר תשפ"ג

מס' שאלון - 538

10

במאי 2023

סמסטר 2023א

מס' מועד 99

4 / 20940

שאלון בחינת גמר

20940 - מבוא לאבטחת המרחב המקוון

משך בחינה: 3 שעות

בשאלון זה **4** עמודים

מבנה הבחינה:

עליכם לענות על ארבע מתוך חמש השאלות.
יש להקפיד על כתב יד קריא.
השתדלו להתחיל כל תשובה בדף חדש.

בהצלחה.

חומר עזר:
מותר לשימוש מחשבון מדעי שלא אוצר מידע.

בהצלחה !!!

אינכם חייבים
להחזיר את השאלון לאוניברסיטה הפתוחה

שאלה 1

נתונה מערכת עם ארבעה משתמשים : איה, בועז, גיא ודנה. לכל אחד מהמשתמשים יש קובץ בבעלותו (קובץ_איה, קובץ_בועז, קובץ_גיא וקובץ_דנה).
כל אחד מהמשתמשים יכול להריץ את הקובץ שבבעלותו.
איה נתנה הרשאות כתיבה לשלושת המשתמשים האחרים (על קובץ איה).
בועז נתן הרשאות כתיבה וקריאה לאיה ודנה (על קובץ_בועז).
גיא (ורק גיא) יכול לקרוא ולכתוב מהקובץ שבבעלותו.
דנה נתנה הרשאות כתיבה וקריאה לאיה וגיא (על קובץ_דנה).

א. רשמו את מטריצת הגישה.
ב. רשמו את המטריצה בצורה של ACL ובצורה של –C-List.
ג. האם ניתן לייצג מטריצה זו ב-UNIX? הראו כיצד או הסבירו מדוע לא.
ד. האם ניתן לייצג מטריצה זו ב-WINDOWS? הראו כיצד או הסבירו מדוע לא.
ה. האם יכולה להיות זרימת מידע לא-חוקית במערכת? הראו כיצד או הסבירו מדוע לא.
ו. האם יש מודל BLP מתאים למערכת? אם כן, הראו השמה של מחלקות הגנה למשתמשים וקבצים המתאימה למודל. אם לא, הסבירו מדוע.
ז. האם ייתכן ערוץ נסתר במערכת? אם כן, הראו דוגמה לערוץ שכזה. אם לא, הסבירו מדוע.

שאלה 2

הסבירו **<u>בקצרה</u>** (אך ללא ויתור על פרטים מהותיים) חמישה מתוך ששת המושגים הבאים. יש ללוות בדוגמה כשמתאים.

1. XSS
2. מוד CFB
3. DEP (Data Execution Prevention)
4. ONE DAY Vulnerability
5. MAC (Massage Authentication Code)
6. Risk Analysis

המשך הבחינה בעמוד הבא

שאלה 3

א. נניח שבהצפנת RSA מצפינים בלוקים בגודל 64 ביט עם מפתח ציבורי e=3 ומודולו של 1024 ביט. בהינתן C=M^e mod n (בלוק מוצפן) הסבירו כיצד לקבל את M (ההודעה המקורית) ללא גישה למפתח הפרטי (d).

רמז: איך הייתם עושים זאת ללא מודולו? כעת שימו לב לגודל הבלוק ולמודולו.

ב. נניח שהגיעה לידיכם הודעה המיועדת לבועז ומוצפנת ב-RSA (כלומר C=M^e mod n) ואתם מעוניינים לקבל את M. המע' של בועז לא סובלת מהבעיה שבסעיף הקודם אך בועז משתמש באותם e ו-d להצפנה כמו לחתימה.

1. בהנחה שאתם יכולים לבקש מבועז שיחתום עבורכם על הודעה כלשהי, מהי ההודעה שעליכם לשלוח לבועז לחתימה כדי לקבל את M?
2. נניח שבועז יזהה אם תשלחו לו את ההודעה מהתת סעיף הקודם לחתימה. נסו למצוא הודעה שתוכלו לשלוח לבועז לחתימה (השונה מההודעה בתת סעיף הקודם) שתאפשר לכם לקבל את M.

שאלה 4

א. האם יש טעם בשימוש ב-IDS ביחד עם Firewall? הסבירו.

האם יש טעם בשימוש ב-Firewall **Stateless** ביחד עם Firewall **Stateful**? הסבירו.

האם יש טעם בשימוש ב-IDS מבוסס חתימות ביחד עם IDS מבוסס זיהוי-אנומליה? הסבירו.

האם IDS מבוסס התנהגות יכול לזהות התקפות יום אפס (zero day)? הסבירו.

ב. כידוע במהלך ביצוע שלב ההתקשרות הראשונית (Handshake) בפרוטוקול SSL (TLS) בין לקוח ושרת, הלקוח יכול לשלוח לשרת מפתח שהוא ייצר בעצמו, או לייצר אותו בצורה משותפת עם השרת על ידי שימוש בפרוטוקול DH. הסבירו את היתרונות והחסרונות של אפשרויות אלו.

ג. באיזה תנאים פרוטוקול קרברוס חשוף להתקפת אופליין על סיסמת המשתמש?

מדוע פרוטוקול SSL לא חשוף להתקפה זו?

המשך הבחינה בעמוד הבא

שאלה 5

כתבו נכון / לא נכון **והסבירו** בקצרה (משפט או שניים) :

א. הצפנה היא דרך לשמור על שלמות הנתונים.

ב. salt מגן מפני התקפות **אונליין**.

ג. ניתן לתכנן תולעת כך שתתפשט בקצב אקספוננציאלי החל מרגע הפעלתה.

ד. אם תמוגר בעיית ה-SQL Injection מן העולם אז לא תהיינה יותר תולעים.

ה. אנטי וירוס יכול לגלות גם וירוסים לא ידועים.

ו. אם נגנבו המפתחות הפרטיים של google אז אין דרך לעדכן את הדפדפן שלא יקבל את התעודה של האתר.

ז. פישינג אפשרי רק אם הקורבן לוחץ על קישור זדוני שנשלח לו ע"י התוקף.

ח. בהצפנת DES במוד CBC הבלוק האחרון יכול לשמש כ-MAC.

ט. שימוש בקנרית למניעת buffer overflow דורש קימפול (הידור) של הקוד בקומפיילר התומך באופציה זו.

י. פונקצית HASH קריפטוגרפית טובה לא סובלת מבעית "פרדוקס יום ההולדת".

ב ה צ ל ח ה !